

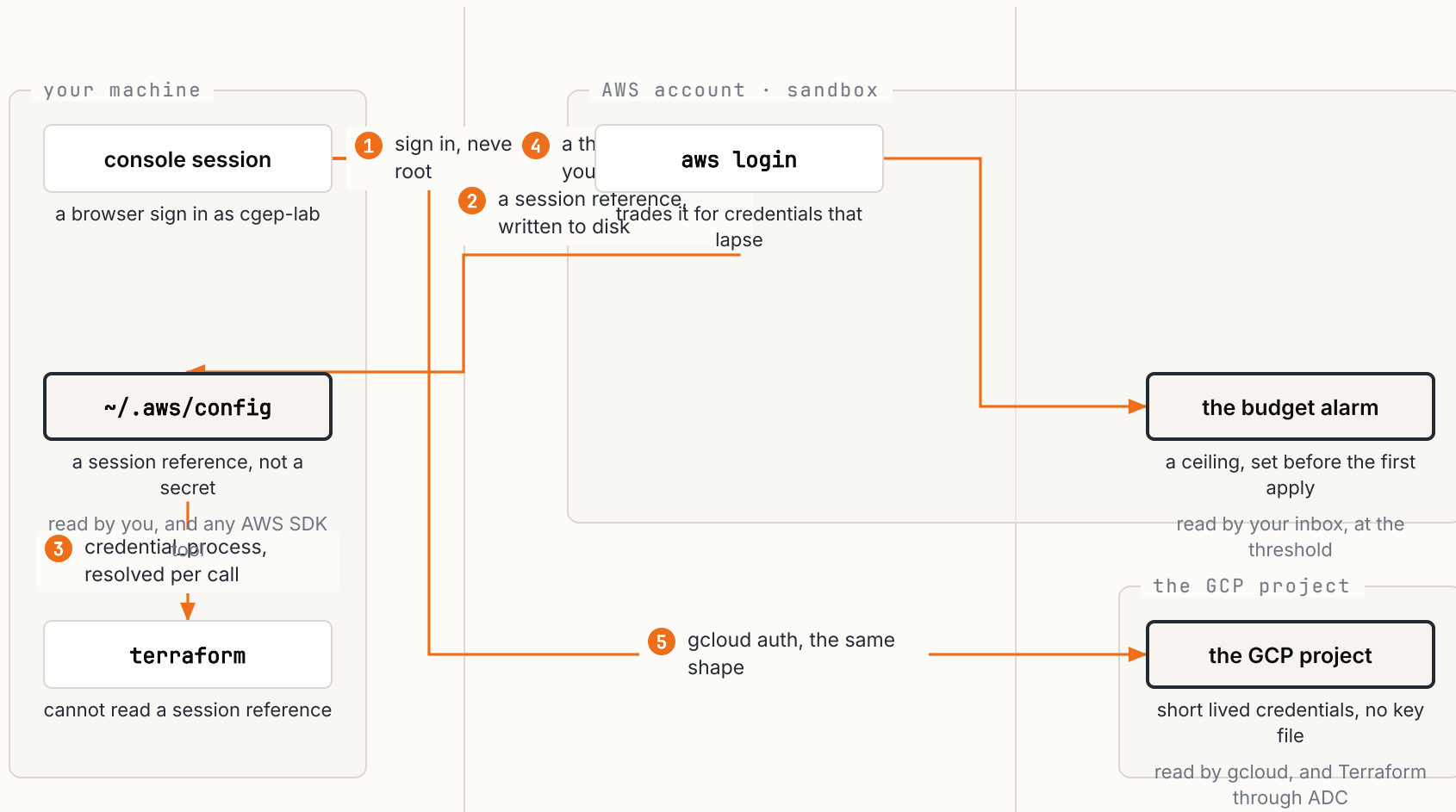
0.1 Prerequisites and Credentials AWS + GCP

Nothing is deployed. You establish an identity in both clouds that expires on its own, and set a ceiling on what everything after this can cost.

DECLARE

ENFORCE

RECORD



PRODUCES

Sandbox account, short lived credentials, toolchain, budget alarms

COST

Free

TIME

90 min

The credential this curriculum exists to eliminate is a permanent access key. Creating one here is a choice you would have to defend later.

2.2

Remote State Backend

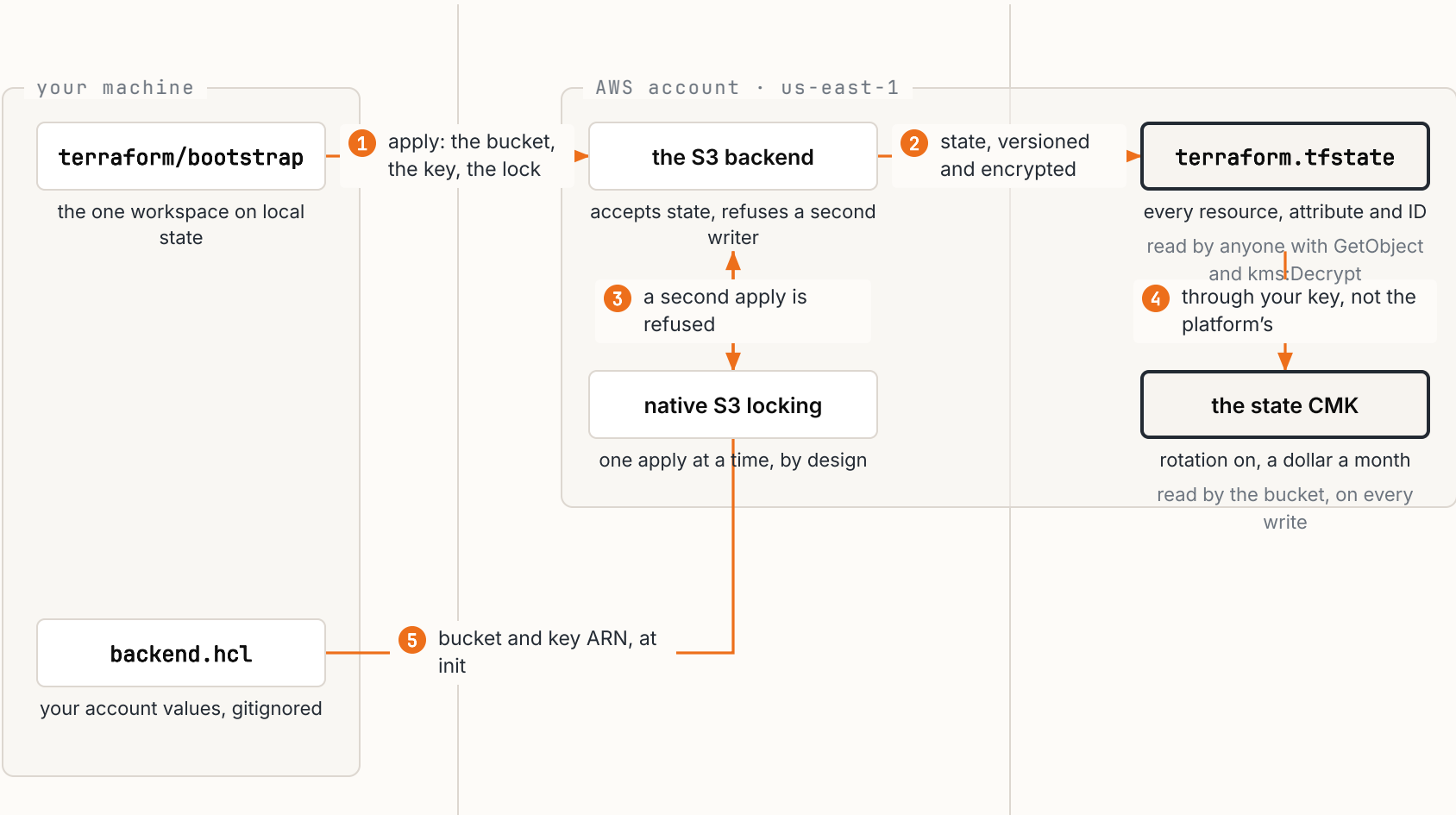
AWS

Terraform's record of what it built moves off your laptop. Without shared state, a fresh CI runner plans against nothing and offers to create everything a second time.

DECLARE

ENFORCE

RECORD



PRODUCES

An S3 backend with native locking

COST

Under \$0.01, plus \$1/mo per KMS key

TIME

20 min

Chapter 4's pipeline is only completable because this exists first. State is plaintext to whoever can decrypt it.

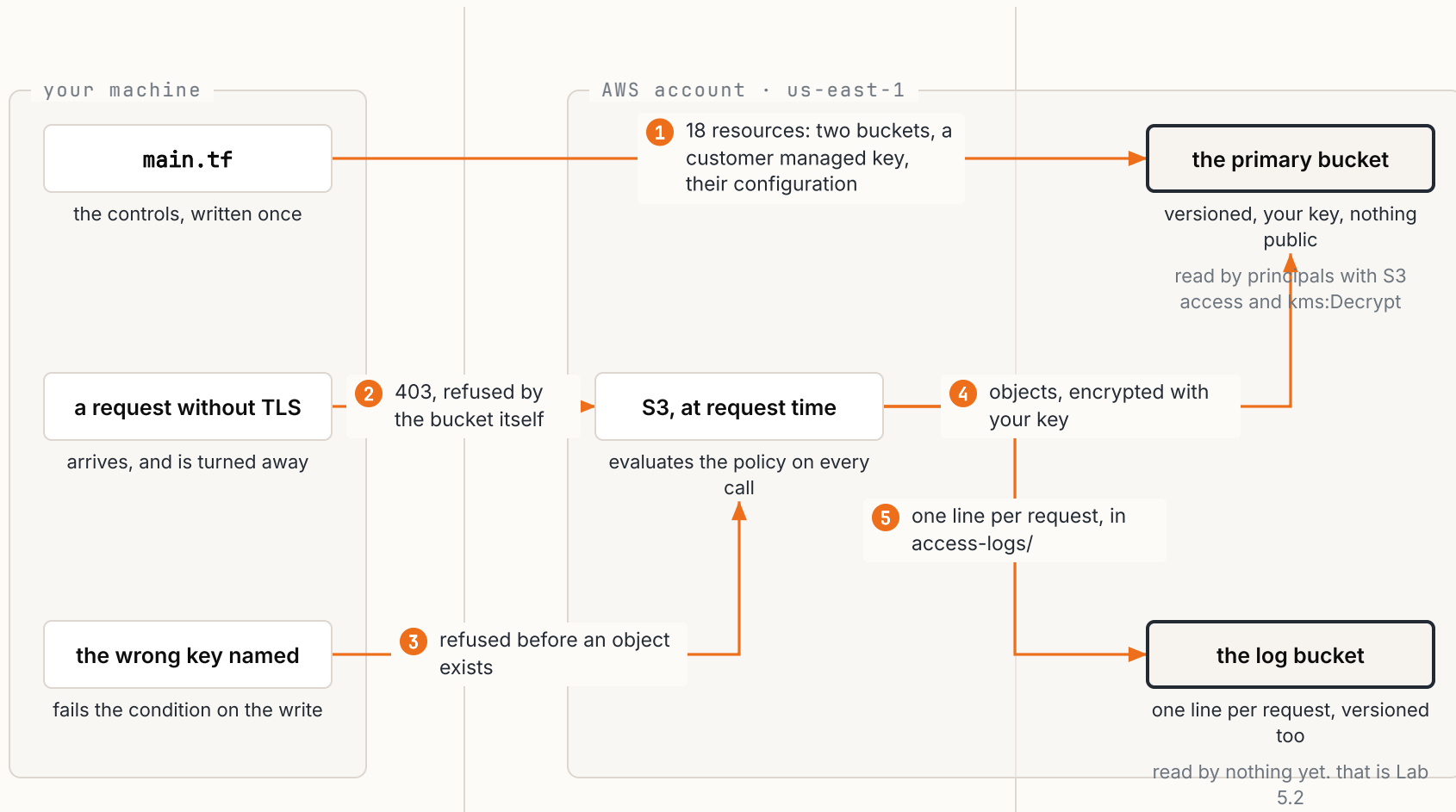
2.3 First Compliant Resource AWS

You describe the controls once as Terraform. AWS then enforces them on every request that follows, without you in the loop.

DECLARE

ENFORCE

RECORD



PRODUCES

18 resources, and the compliant-s3 primitive the rest of the curriculum reuses

COST

About \$1/mo per KMS key

TIME

60 to 75 min

Refused at request time: SC-8, SC-8(1), SC-12, SC-13, SC-28, SC-28(1), AC-3, AC-6, AU-3, AU-9, AU-11, CP-9, SI-7, CM-6, CM-8.

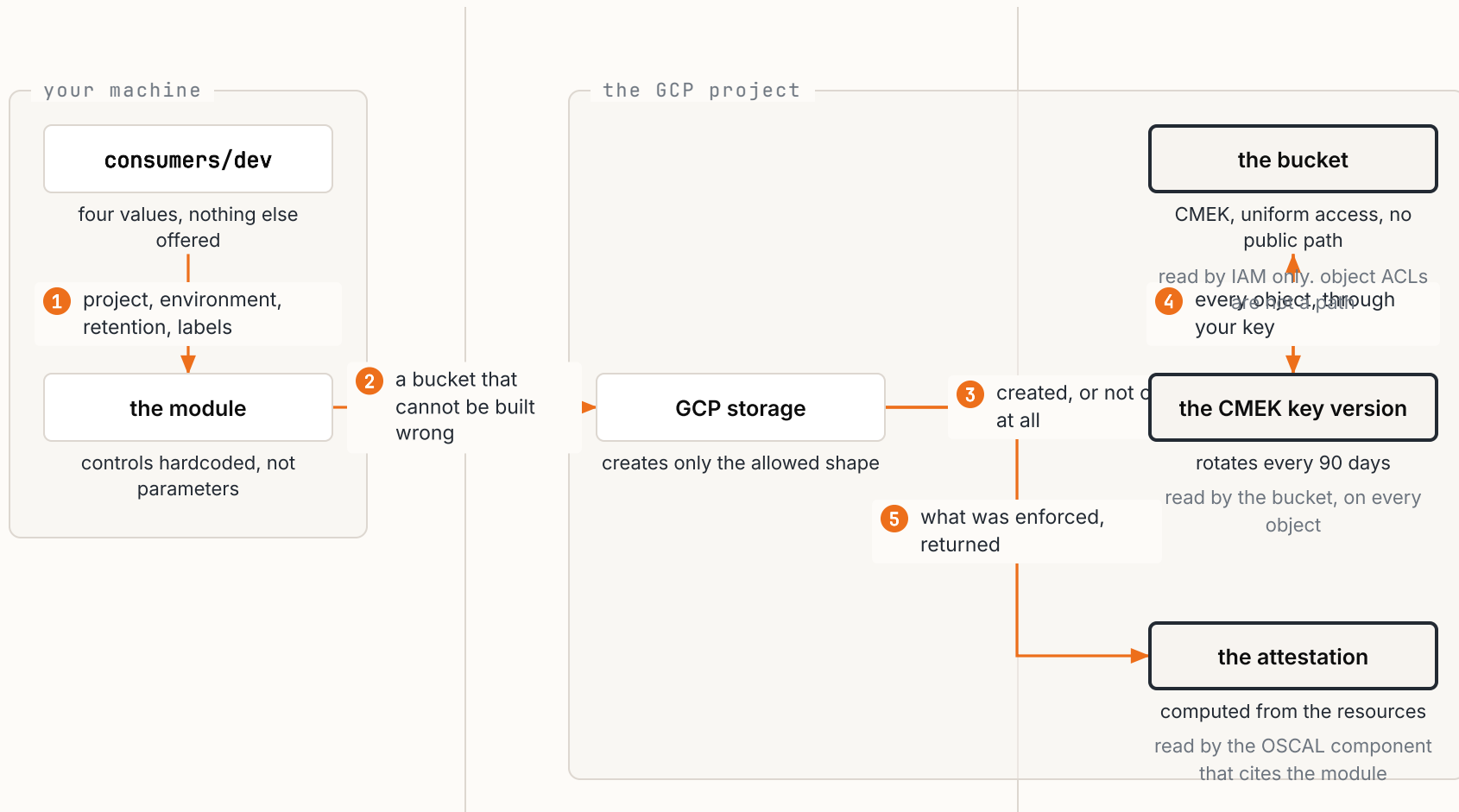
2.4 Modules for Compliance GCP

A module turns a set of decisions into a default every consumer inherits, so the argument happens once instead of in every review.

DECLARE

ENFORCE

RECORD



PRODUCES

A reusable module with CMEK and a consumer pattern

COST

About \$0.06 per key version per month

TIME

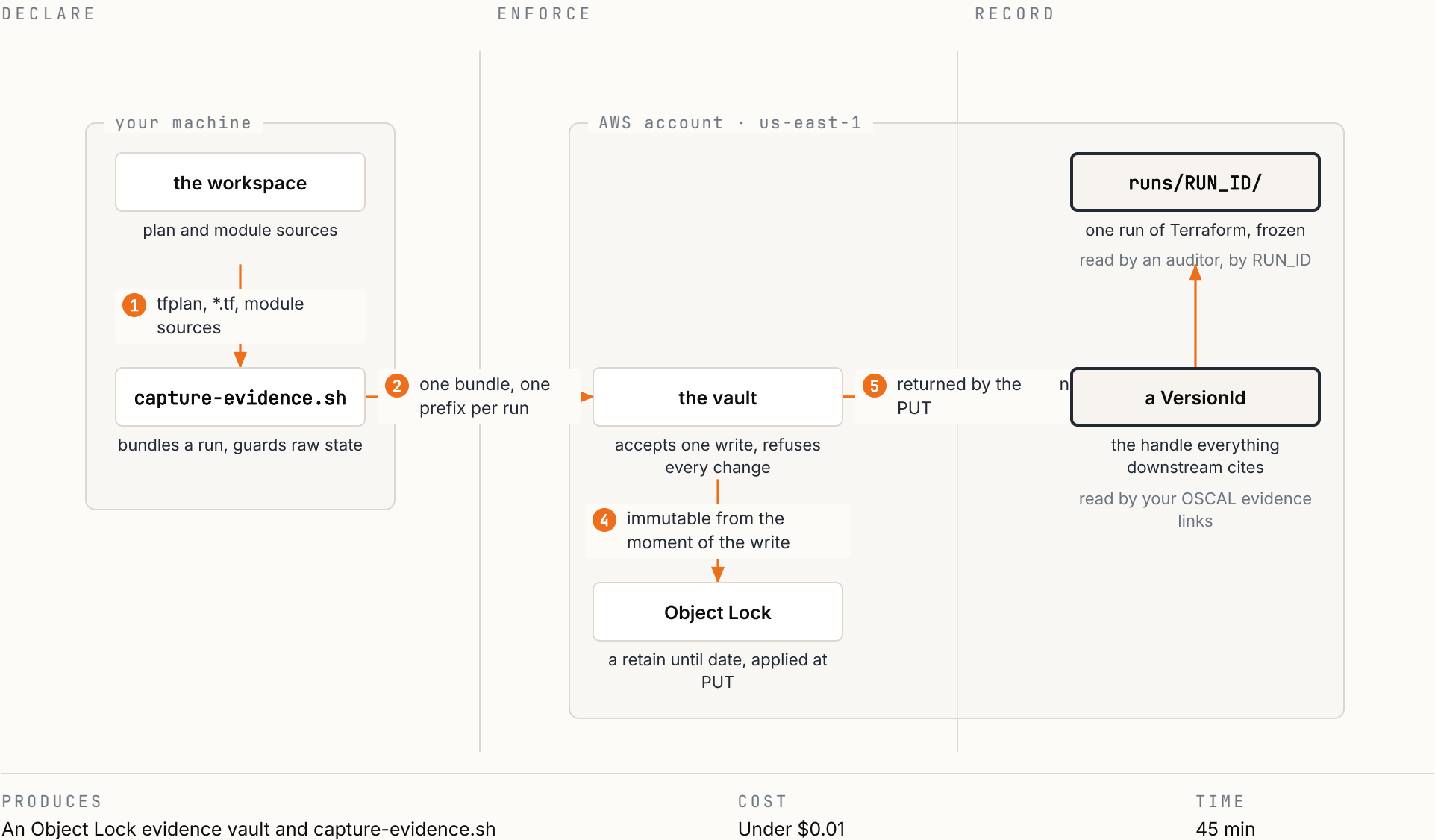
45 to 60 min

What a team cannot configure, it cannot misconfigure.

2.5

laC as Compliance Evidence AWS

Evidence you can delete is not evidence. Object Lock makes a run permanent, and that cuts both ways: a captured secret becomes permanently undeletable.



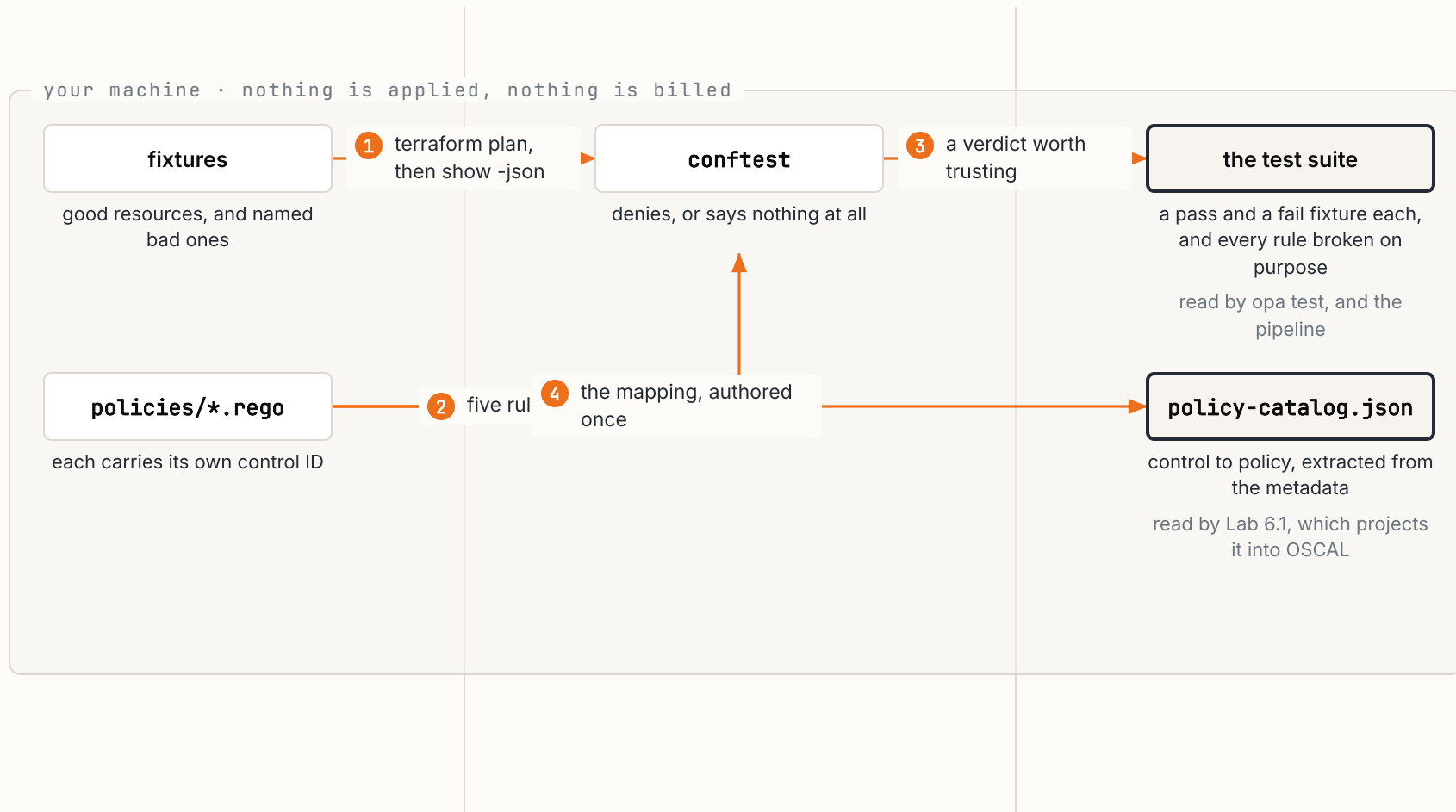
3.3 Writing Rego GCP

A policy no test constraints cannot fail. This lab breaks every policy on purpose and requires the tests to notice.

DECLARE

ENFORCE

RECORD



PRODUCES

A policy library with metadata and test fixtures

COST

Free

TIME

Plan only, about 105 min
with Lab 3.4

A mapping typed twice eventually disagrees with itself, so it is extracted rather than retyped.

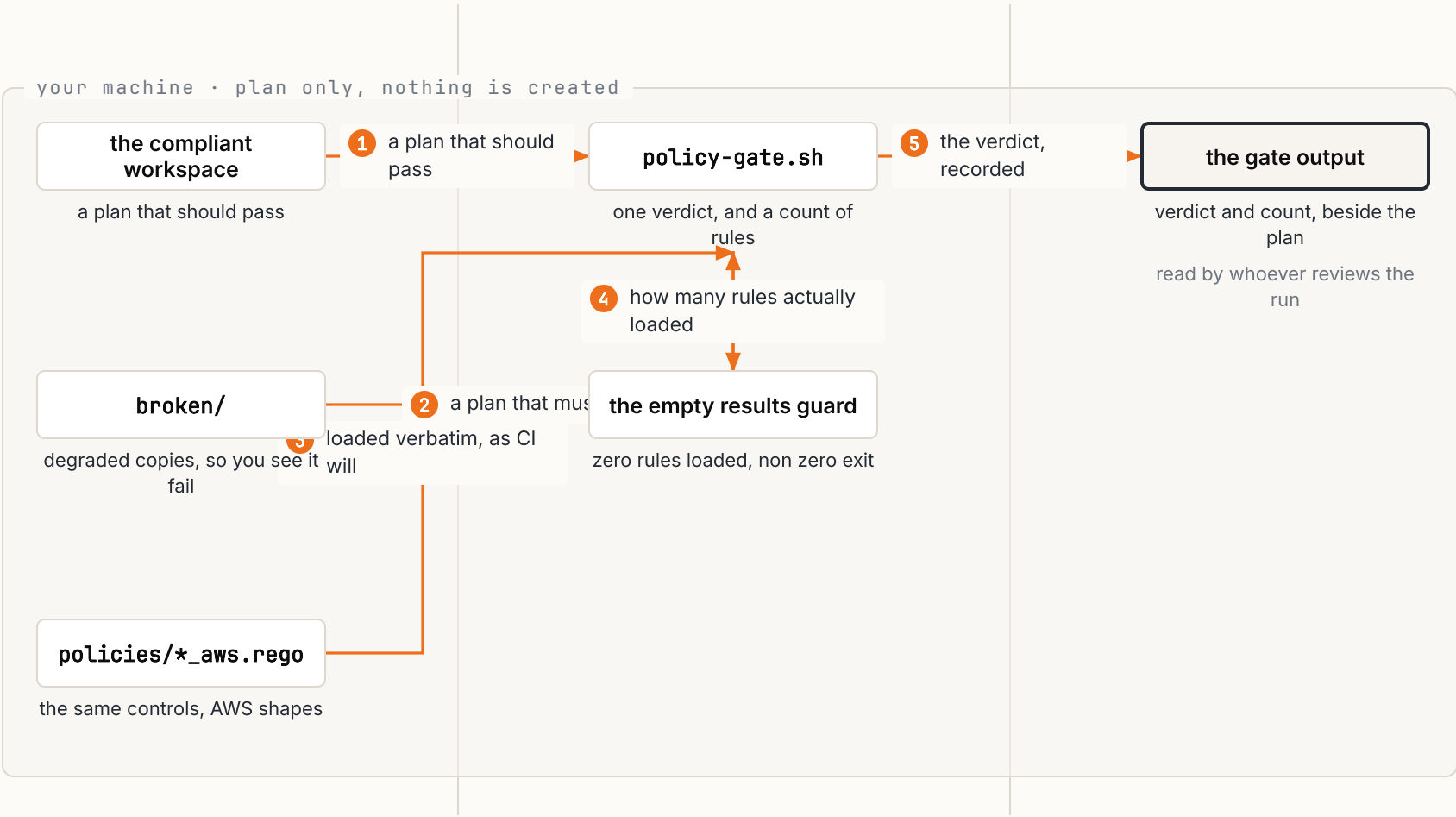
3.4 Conftest and Terraform AWS

The gate runs against a Terraform plan, so a violation is caught before anything is created rather than found after it already exists.

DECLARE

ENFORCE

RECORD



PRODUCES

AWS policy variants and policy-gate.sh

COST

Free

TIME

Plan only

CI shells out to this script rather than reimplementing it, so what runs there is what ran here.

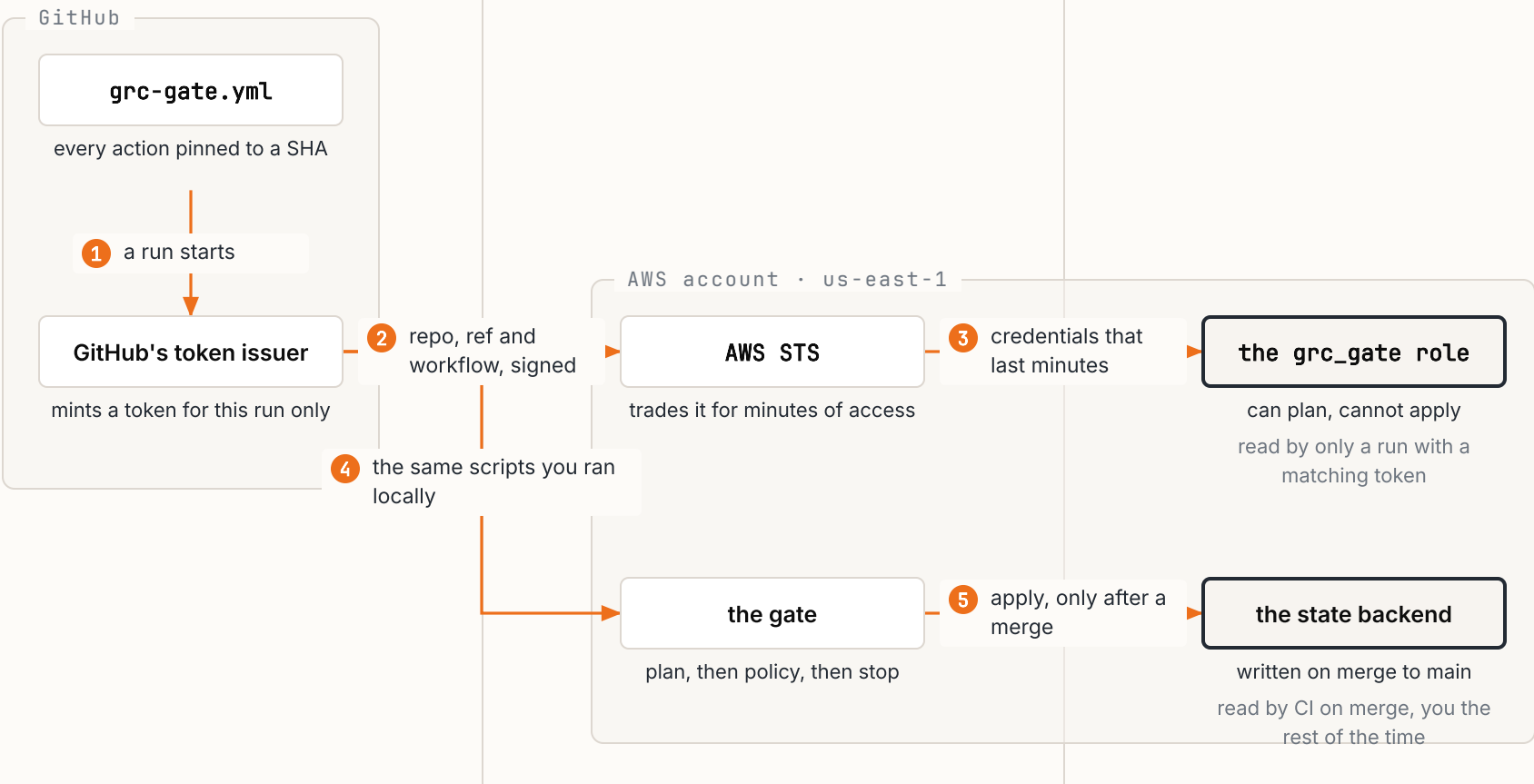
4.3 GRC Evidence Pipeline AWS

The checks a human ran by hand become the thing that must pass before a merge.

DECLARE

ENFORCE

RECORD



PRODUCES

.github/workflows/grc-gate.yml

COST

Free

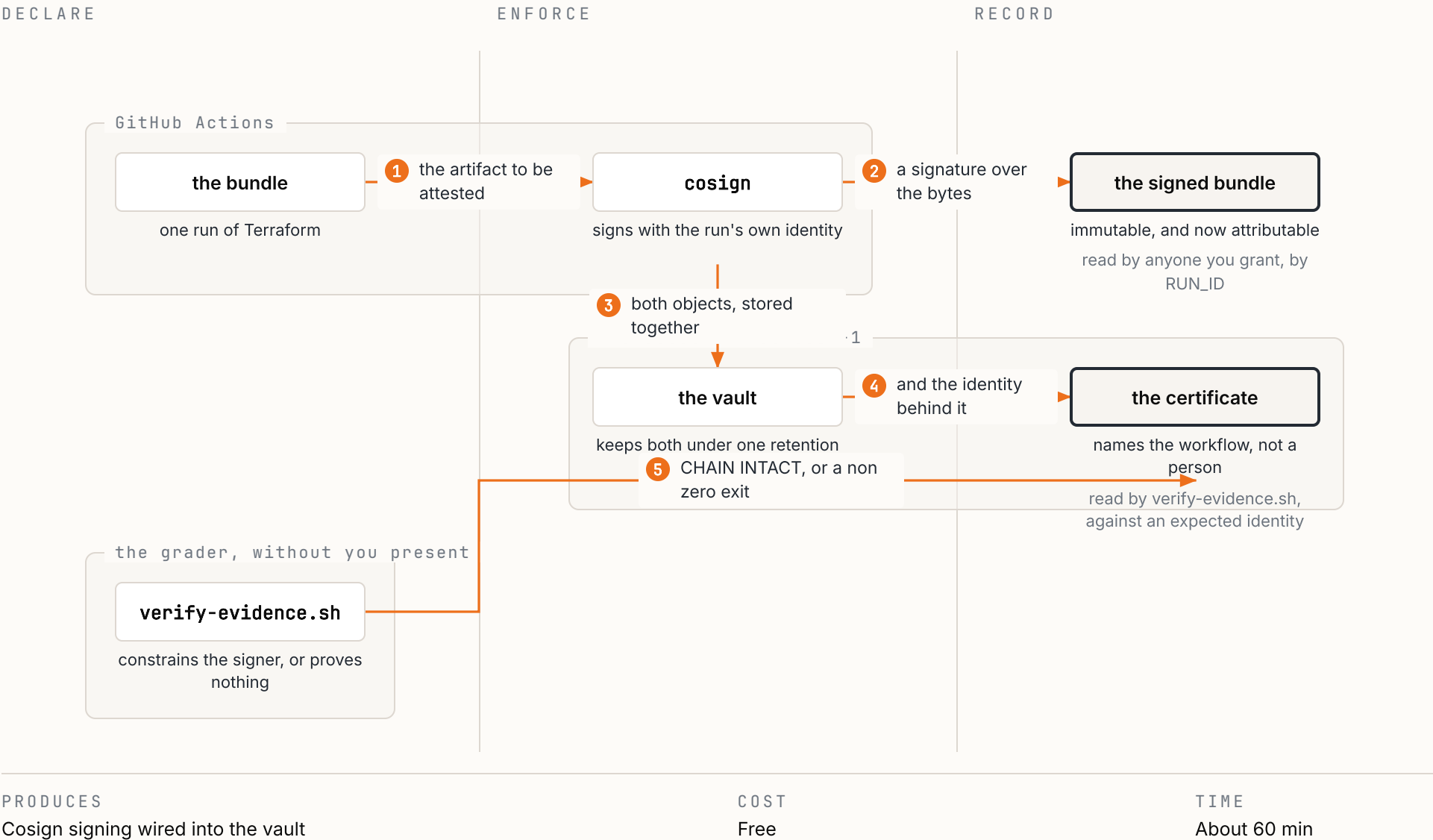
TIME

About 90 min

A compromised workflow reads your infrastructure and stops there, because the role cannot apply.

4.4 Chain of Custody AWS

A signature answers two questions: who produced this artifact, and has it changed since. Verification has to constrain the signer, or it answers neither.



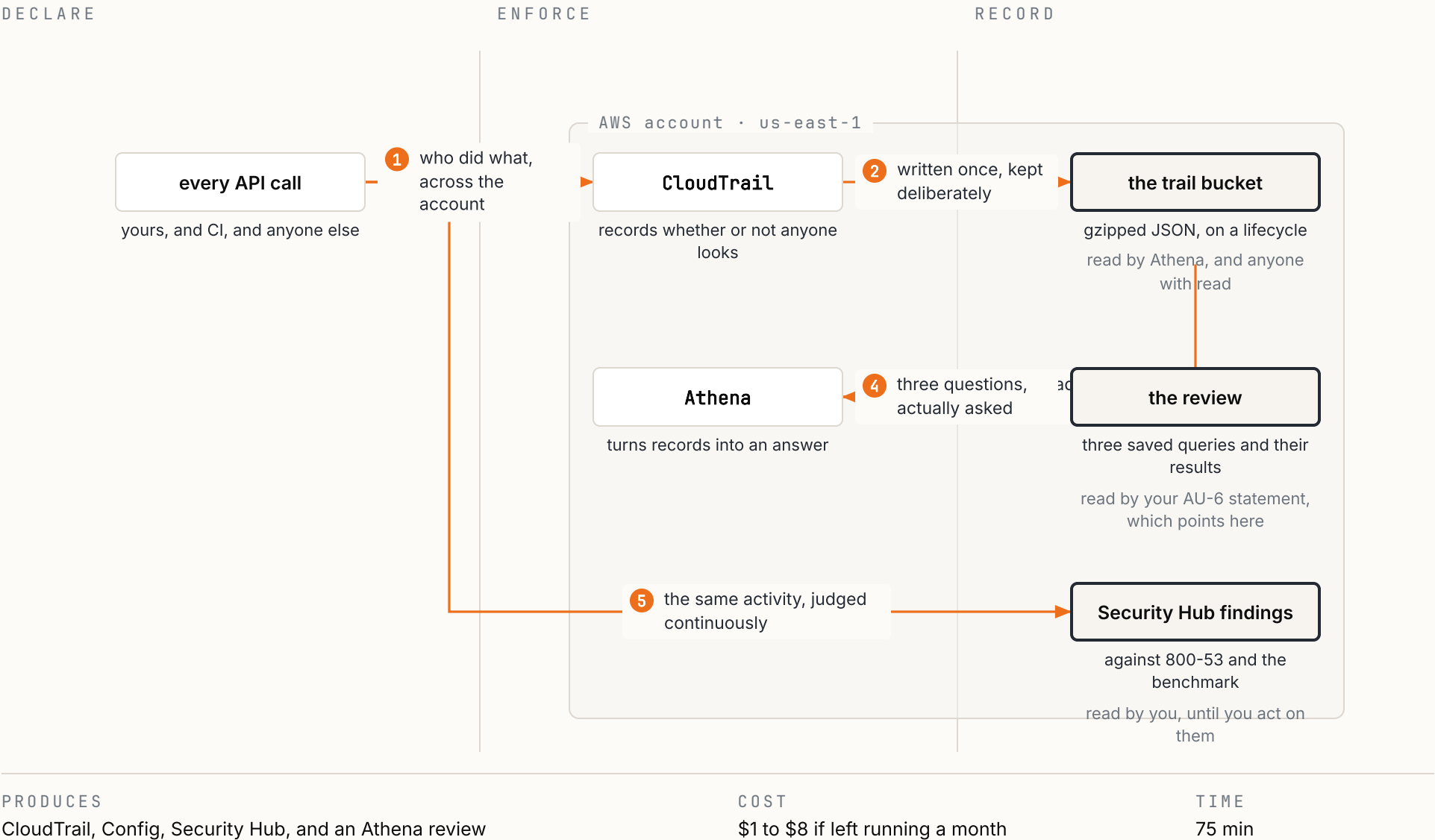
A verify script that accepts any valid signature verifies nothing.

5.2

AWS Security Services

AWS

Collecting logs is AU-3 and AU-11. Actually reading them is AU-6, and that costs a query engine.



Enforced or evidenced here: AU-2, AU-6, AU-10, AU-12, SI-4, RA-5, CM-2. Data events are scoped to the vault, because they bill per event.

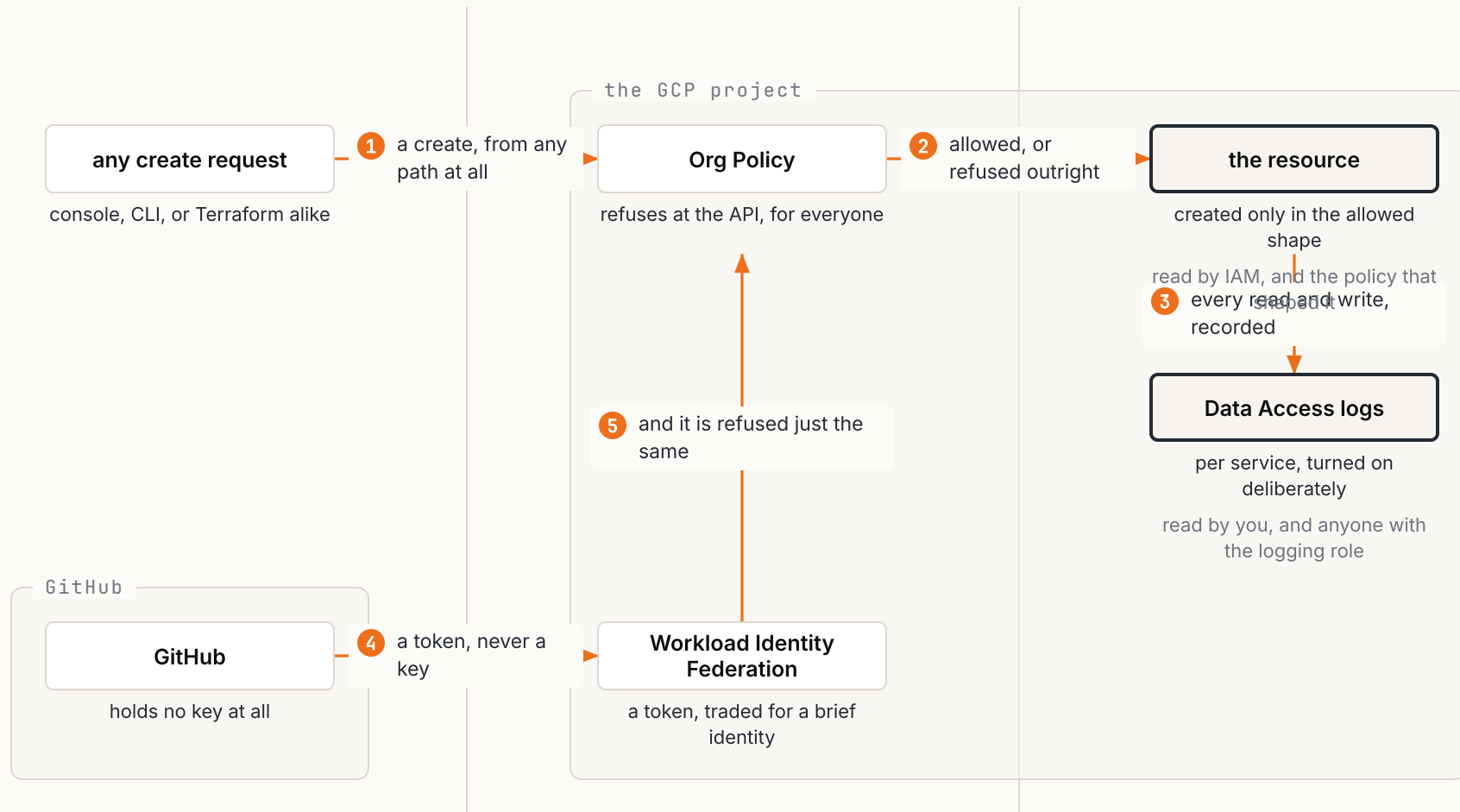
5.4 GCP Security Services GCP

An org policy stops the action at the API for everyone, including someone clicking in the console. That is stronger than a standard a module can offer.

DECLARE

ENFORCE

RECORD



PRODUCES

Org Policy, Workload Identity Federation, and Data Access logs

COST

Pennies

TIME

75 to 90 min

There is no drift to detect, because there is no drift. What the platform provides, record as inherited.

6.1

Introduction to OSCALno cloud

The control narrative becomes a machine readable artifact a tool can validate, instead of a document a human rereads and hopes is still true.

